

SAR Platform API Documentation

1. Thông tin chung

– Base URL mặc định:

○ HTTPS: <https://sar-be.onrender.com>

– Prefix API: phần lớn endpoint bắt đầu bằng /api.

– Content-Type cho body JSON: [application/json](#).

– Auth: các endpoint có [Authorize] cần header Authorization: Bearer {accessToken}.

– Permission: nhiều endpoint còn cần JWT claim permission khớp với permission code ghi trong tài liệu.

– Tài liệu OpenAPI/Scalar chỉ được map ở môi trường Development.

- Admin account:

username: admin

password: Admin@123

1.1 Mẫu Lỗi Chuẩn

Global exception middleware trả về JSON dạng:

```
{
  "statusCode": 400,
  "message": "Yêu cầu không hợp lệ. Vui lòng kiểm tra lại dữ liệu.",
  "traceld": "0HN...",
  "errors": [
    "Email không hợp lệ."
  ]
}
```

Mapping chính:

Exception	HTTP	Ghi chú
ValidationException	400	Lỗi validate input hoặc nghiệp vụ
DomainException	400	Lỗi domain
UnauthorizedException	401	Sai token, login hoặc refresh token
NotFoundException	404	Không tìm thấy resource
ConflictException	409	Dữ liệu bị trùng hoặc xung đột
MetaGraphApiException	502	Lỗi khi gọi Meta Graph API

Lỗi khác	500	Production trả message chung, không expose stack trace
----------	-----	--

Lưu ý: nếu request bị chặn bởi auth/permission middleware, response 401 hoặc 403 có thể không có JSON body.

1.2 Header Dùng Chung

Authorization: Bearer eyJ...

Content-Type: application/json

1.3 Soft Delete

Các API delete thông thường của hệ thống sử dụng soft delete nếu entity có IsDeleted. Record bị soft delete không được trả về ở API listing/detail thông thường. Với Social Media Integration và Social Media Page, delete sẽ set IsDeleted = true cho entity chính và các entity con liên quan theo rule ở mục Social Media.

2. Auth Và Tài Khoản Hiện Tại

2.1 Login

- Khi FE gọi: màn hình đăng nhập.
- Endpoint: POST /api/auth/login
- Auth: không cần.

Request:

```
{
  "usernameOrEmail": "admin@sar.local",
  "password": "P@ssw0rd!"
}
```

Response 200:

```
{
  "accessToken": "eyJ...",
  "refreshToken": "a-refresh-token",
  "tokenType": "Bearer",
  "expiresIn": 3600,
  "user": {
    "id": "11111111-1111-1111-1111-111111111111",
    "username": "admin",
    "email": "admin@sar.local",
    "firstTimeLogin": false
  },
  "role": {
    "id": "22222222-2222-2222-2222-222222222222",
    "name": "Admin",

```

```
    "code": "ADMIN"
  },
  "permissions": [
    "ROLE_MANAGEMENT.ROLE_LIST.VIEW"
  ]
}
```

FE note: lưu accessToken, refreshToken, permission list và role. Dùng permission list để ẩn/hiện menu hoặc action.

2.2 Refresh Token

- Endpoint: POST /api/auth/refresh-token
- Auth: không cần Bearer token, body cần token cũ.

Request:

```
{
  "accessToken": "old-access-token",
  "refreshToken": "stored-refresh-token"
}
```

Response 200:

```
{
  "accessToken": "new-access-token",
  "refreshToken": "new-refresh-token",
  "tokenType": "Bearer",
  "expiresIn": 3600,
  "permissions": [
    "SOCIAL_MEDIA.FACEBOOK_INTEGRATION.VIEW"
  ]
}
```

2.3 Logout

- Endpoint: POST /api/auth/logout
- Auth: controller hiện tại không bắt buộc Bearer token.

Request:

```
{
  "refreshToken": "stored-refresh-token"
}
```

Response 200:

```
{
  "success": true
}
```

2.4 Lấy Profile User Hiện Tại

- Endpoint: GET /api/me
- Auth: Bearer token.

Response 200:

```
{
  "id": "11111111-1111-1111-1111-111111111111",
  "username": "admin",
  "email": "admin@sar.local",
  "firstTimeLogin": false,
  "role": {
    "id": "22222222-2222-2222-2222-222222222222",
    "name": "Admin",
    "code": "ADMIN"
  }
}
```

2.5 Lấy Permissions Và Menu Của User Hiện Tại

- Endpoint: GET /api/me/permissions
- Auth: Bearer token.

Response 200:

```
{
  "user": {
    "id": "11111111-1111-1111-1111-111111111111",
    "username": "admin",
    "email": "admin@sar.local"
  },
  "role": {
    "id": "22222222-2222-2222-2222-222222222222",
    "name": "Admin",
    "code": "ADMIN"
  },
  "permissions": [
    "PERMISSION_MANAGEMENT.FEATURE_CONFIG.VIEW"
  ],
  "menus": [
    {
      "id": "33333333-3333-3333-3333-333333333333",
      "name": "Permission Management",
      "code": "PERMISSION_MANAGEMENT",
      "displayOrder": 1,
      "pages": [
        {

```

```

    "id": "44444444-4444-4444-4444-444444444444",
    "name": "Feature Config",
    "code": "FEATURE_CONFIG",
    "route": "/permissions/features",
    "icon": "settings",
    "displayOrder": 1
  }
]
}

```

3. Business Partner

Business Partner là khách hàng sử dụng chatbot platform. Tất cả API trong mục này cần Bearer token.

Field chính theo DTO hiện tại:

Field	Ý nghĩa
brandName	Tên thương hiệu
logoUrl	URL hình ảnh/logo thương hiệu, nullable
email	Email owner của Business Partner
phone	Số điện thoại
representativeName	Người đại diện
representativeEmail	Email người đại diện
isActive	Trạng thái active/inactive
createdAt, updatedAt	Audit time

Repository hiện tại loại bỏ record IsDeleted = true khỏi listing/detail.

3.1 Danh Sách Business Partner

- Endpoint: GET
/api/business-partners?keyword=&isActive=&pageNumber=1&pageSize=20
- Permission: BUSINESS_PARTNER.PROFILE.VIEW
- Query:
 - keyword: optional.
 - isActive: optional boolean.
 - pageNumber: mặc định 1.
 - pageSize: mặc định 20, service giới hạn tối đa 100.

Response 200:

```

{
  "items": [
    {
      "id": "aaaaaaaa-aaaa-aaaa-aaaa-aaaaaaaaaaaa",
      "brandName": "SAR Coffee",
      "logoUrl": "https://cdn.example.com/logo.png",
      "email": "owner@sarcoffee.vn",
      "phone": "0900000000",
      "representativeName": "Nguyen Van A",
      "representativeEmail": "rep@sarcoffee.vn",
      "isActive": true,
      "createdAt": "2026-06-16T10:00:00Z",
      "updatedAt": null,
      "accountCreated": null,
      "representativeEmailSent": null,
      "businessOwnerEmailSent": null
    }
  ],
  "pageNumber": 1,
  "pageSize": 20,
  "totalCount": 1
}

```

3.2 Chi Tiết Business Partner

- Endpoint: GET /api/business-partners/{businessPartnerId}
- Permission: BUSINESS_PARTNER.PROFILE.VIEW

Response 200:

```

{
  "id": "aaaaaaaa-aaaa-aaaa-aaaa-aaaaaaaaaaaa",
  "brandName": "SAR Coffee",
  "logoUrl": null,
  "email": "owner@sarcoffee.vn",
  "phone": "0900000000",
  "representativeName": "Nguyen Van A",
  "representativeEmail": "rep@sarcoffee.vn",
  "isActive": true,
  "createdAt": "2026-06-16T10:00:00Z",
  "updatedAt": null,
  "usersCount": 1,
  "integrationsCount": 0
}

```

3.3 Tạo Business Partner

- Endpoint: POST /api/business-partners

- Permission: BUSINESS_PARTNER.PROFILE.CREATE
- Status thành công: 201 Created.

Request:

```
{
  "brandName": "SAR Coffee",
  "logoUrl": "https://cdn.example.com/logo.png",
  "email": "owner@sarcoffee.vn",
  "phone": "0900000000",
  "representativeName": "Nguyen Van A",
  "representativeEmail": "rep@sarcoffee.vn"
}
```

Response 201:

```
{
  "id": "aaaaaaaa-aaaa-aaaa-aaaa-aaaaaaaaaaaa",
  "brandName": "SAR Coffee",
  "logoUrl": "https://cdn.example.com/logo.png",
  "email": "owner@sarcoffee.vn",
  "phone": "0900000000",
  "representativeName": "Nguyen Van A",
  "representativeEmail": "rep@sarcoffee.vn",
  "isActive": true,
  "createdAt": "2026-06-16T10:00:00Z",
  "updatedAt": null,
  "accountCreated": true,
  "representativeEmailSent": true,
  "businessOwnerEmailSent": true
}
```

FE note: BE tự tạo account representative và gửi email. API không trả password.

3.4 Cập Nhật Business Partner

- Endpoint: PUT /api/business-partners/{businessPartnerId}
- Permission: BUSINESS_PARTNER.PROFILE.UPDATE

Request:

```
{
  "brandName": "SAR Coffee Updated",
  "logoUrl": null,
  "email": "owner@sarcoffee.vn",
  "phone": "0911111111",
  "representativeName": "Nguyen Van B",
  "representativeEmail": "rep@sarcoffee.vn",
}
```

```
"isActive": true
}
```

Response 200: BusinessPartnerResponse.

3.5 Xóa Business Partner

- Endpoint: DELETE /api/business-partners/{businessPartnerId}
- Permission: BUSINESS_PARTNER.PROFILE.DELETE
- Response: 204 No Content.

Theo source hiện tại action tên DeactivateBusinessPartnerAsync. Repository listing/detail không trả record IsDeleted = true; nếu service chỉ deactivate thì record vẫn còn nhưng isActive = false. FE nên xem đây là thao tác xóa/ngưng sử dụng theo behavior backend hiện tại.

4. Permission, Role Và Menu Configuration

Tất cả API trong mục này cần Bearer token và permission tương ứng.

4.1 Roles

API	Permission	Khi FE gọi
GET /api/roles?keyword=&isActive=&pageNumber=1&pageSize=20	ROLE_MANAGEMENT.ROLE_LIST.VIEW	List role
GET /api/roles/{roleId}	ROLE_MANAGEMENT.ROLE_LIST.VIEW	Detail/edit role
POST /api/roles	ROLE_MANAGEMENT.ROLE_LIST.CREATE	Tạo role
PUT /api/roles/{roleId}	ROLE_MANAGEMENT.ROLE_LIST.UPDATE	Cập nhật role
DELETE /api/roles/{roleId}	ROLE_MANAGEMENT.ROLE_LIST.DELETE	Xóa role
GET /api/roles/{roleId}/permissions/matrix	PERMISSION_MANAGEMENT.ROLE_PERMISSION_CONFIG.VIEW	Màn hình gán quyền
PUT /api/roles/{roleId}/permissions	PERMISSION_MANAGEMENT.ROLE_PERMISSION_CONFIG.UPDATE	Replace toàn bộ quyền role
PATCH /api/roles/{roleId}/permissions	PERMISSION_MANAGEMENT.ROLE_PERMISSION_CONFIG.UPDATE	Grant/revoke một phần
POST /api/roles/{targetRoleId}/permissions/copy-from/{sourceRoleId}	PERMISSION_MANAGEMENT.ROLE_PERMISSION_CONFIG.UPDATE	Copy quyền từ role khác

4.2 Features, Pages, Actions

Nhóm	API chính	Permission xem
Features	GET/POST/PUT/DELETE /api/features	PERMISSION_MANAGEMENT.FEATURE_CONFIG.VIEW
Pages	GET/POST/PUT/DELETE /api/pages	PERMISSION_MANAGEMENT.PAGE_CONFIG.VIEW
Permission actions	GET/POST/PUT/DELETE /api/permission-actions	PERMISSION_MANAGEMENT.ACTION_CONFIG.VIEW
Page actions	GET/POST/PUT/DELETE /api/page-actions	PERMISSION_MANAGEMENT.PAGE_ACTION_CONFIG.VIEW
System definitions	GET /api/system-module-definitions, GET /api/system-action-definitions	Theo page config/action config

5. Social Media Integration Theo Business Partner

Đây là flow quản trị tích hợp Meta/Facebook cho từng Business Partner.

Flow tạo mới chính hiện tại:

Tạo Business Partner

|
v

POST /api/business-partners/{businessPartnerId}/social-media/integrations

|
v

Lưu Social Media Integration + Social Media Pages + Bot Schedule theo từng page trong một transaction

Không dùng flow cũ tạo app config riêng, chọn page riêng, rồi tạo schedule riêng cho màn hình tạo mới. Các endpoint cũ vẫn còn trong source để tương thích hoặc vận hành legacy, nhưng không nên mô tả là flow chính.

5.1 Data Relationship

BusinessPartner

1 - N BusinessPartnerSocialMediaIntegration

1 - N BusinessPartnerSocialMediaPage

1 - N BotWorkingSchedule

Ghi chú: mỗi page có thể có nhiều BotWorkingSchedule, mỗi schedule ứng với một ngày làm việc.

Entity	Field chính
BusinessPartner	Id, BrandName, LogoUrl, Email, Phone, RepresentativeName, RepresentativeEmail, IsActive, IsDeleted, CreatedAt, UpdatedAt
BusinessPartnerSocialMediaIntegration	Id, BusinessPartnerId, SocialMediaProviderId, AppId, ProtectedAppSecret, Status, AuthorizedAt, LastSyncedAt, ExternalUserId, ExternalUserName, IsDeleted, CreatedAt, UpdatedAt
BusinessPartnerSocialMediaPage	Id, IntegrationId, ExternalPageId, PageName, PageAvatarUrl, ProtectedPageAccessToken, IsBotEnabled, IsActive, IsDeleted, CreatedAt, UpdatedAt

BotWorkingSchedule Id, SocialMediaPageId, DayOfWeek, StartTime, EndTime, TimeZoneId, IsActive, IsDeleted, CreatedAt, UpdatedAt

5.2 Danh Sách Social Media Providers

- Endpoint: GET /api/social-media/providers
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.VIEW

Response 200:

```
[
  {
    "id": "17171717-1717-1717-1717-171717171717",
    "name": "Facebook",
    "code": "FACEBOOK",
    "description": "Facebook Messenger",
    "isActive": true
  }
]
```

5.3 Danh Sách Integrations Của Business Partner

- Endpoint: GET /api/business-partners/{businessPartnerId}/social-media/integrations
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.VIEW
- Không trả integration đã soft delete.
- pageCount và activeBotPagesCount không tính page đã soft delete.

Response 200:

```
[
  {
    "id": "18181818-1818-1818-1818-181818181818",
    "providerName": "Facebook",
    "providerCode": "FACEBOOK",
    "appId": "facebook-app-id",
    "status": "Active",
    "authorizedAt": "2026-06-16T10:00:00Z",
    "pagesCount": 2,
    "activeBotPagesCount": 1
  }
]
```

5.4 Chi Tiết Integration

- Endpoint: GET
/api/business-partners/{businessPartnerId}/social-media/integrations/{integrationId}

- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.VIEW
- Không trả integration/page/schedule đã soft delete.

Response 200:

```
{
  "id": "18181818-1818-1818-1818-181818181818",
  "businessPartnerId": "aaaaaaaa-aaaa-aaaa-aaaa-aaaaaaaaaaaaa",
  "provider": {
    "id": "17171717-1717-1717-1717-171717171717",
    "name": "Facebook",
    "code": "FACEBOOK"
  },
  "appId": "facebook-app-id",
  "status": "Active",
  "authorizedAt": "2026-06-16T10:00:00Z",
  "lastSyncedAt": "2026-06-16T10:05:00Z",
  "externalUserId": "meta-user-id",
  "externalUserName": "Meta User",
  "pages": [
    {
      "id": "19191919-1919-1919-1919-191919191919",
      "externalPageId": "123456789",
      "pageName": "SAR Demo Page",
      "pageAvatarUrl": "https://example.com/avatar.png",
      "isBotEnabled": true,
      "isActive": true,
      "schedules": [
        {
          "id": "20202020-2020-2020-2020-202020202020",
          "dayOfWeek": "Monday",
          "startTime": "18:00",
          "endTime": "00:00",
          "timeZoneId": "Asia/Ho_Chi_Minh",
          "isActive": true
        }
      ]
    }
  ]
}
```

5.5 Tạo Social Media Integration Kèm Pages Và Bot Schedule

- Endpoint: POST
/api/business-partners/{businessPartnerId}/social-media/integrations
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.CREATE

- Response thành công hiện tại: 200 OK.
- Đây là API tạo mới chính cho flow hiện tại.
- Toàn bộ integration, pages và schedules được lưu trong một transaction.

Request:

```
{
  "provider": "Facebook",
  "appId": "facebook-app-id",
  "appSecret": "facebook-app-secret",
  "pages": [
    {
      "externalPageId": "123456789",
      "pageName": "SAR Demo Page",
      "pageAvatarUrl": "https://example.com/avatar.png",
      "pageImageUrl": null,
      "status": "Active",
      "botSchedule": {
        "timezone": "Asia/Ho_Chi_Minh",
        "workingDays": [
          "Monday",
          "Wednesday",
          "Friday"
        ],
        "startTime": "18:00",
        "endTime": "00:00"
      }
    }
  ]
}
```

Response 200:

```
{
  "businessPartnerId": "aaaaaaaa-aaaa-aaaa-aaaa-aaaaaaaaaaaa",
  "integrationId": "18181818-1818-1818-1818-181818181818",
  "providerCode": "FACEBOOK",
  "appId": "facebook-app-id",
  "status": "PendingAuthorization",
  "pages": [
    {
      "id": "19191919-1919-1919-1919-191919191919",
      "externalPageId": "123456789",
      "pageName": "SAR Demo Page",
      "isBotEnabled": true,
      "isActive": true,
      "schedulesCount": 3
    }
  ]
}
```

```

],
"message": "Tạo Social Media Integration thành công."
}

```

Validate và rule:

- businessPartnerId lấy từ route, bắt buộc là Business Partner tồn tại, chưa bị soft delete và đang active.
- provider bắt buộc. Source hiện tại normalize Facebook hoặc Meta về provider code FACEBOOK.
- appId bắt buộc.
- appSecret bắt buộc, là thông tin nhạy cảm và được lưu dưới dạng protected/encrypted.
- pages bắt buộc và phải có ít nhất một page.
- Mỗi page phải có externalPageId, pageName, botSchedule.
- pageAvatarUrl và pageImageUrl nullable. Source ưu tiên pageAvatarUrl, nếu trống thì dùng pageImageUrl.
- status nullable, mặc định Active. Giá trị hợp lệ: Active, Inactive.
- Không cho phép tạo integration active/non-deleted trùng provider cho cùng Business Partner. Lỗi nghiệp vụ hiện tại: SocialMediaIntegrationAlreadyExists.
- Không cho phép trùng externalPageId trong cùng request.
- Nếu integration/page cùng provider đã bị soft delete, source hiện tại ưu tiên restore bản cũ thay vì tạo record mới.

5.6 Bot Schedule

Bot Schedule thuộc về từng Social Media Page. Schedule dùng để xác định thời gian bot AI được phép tự động xử lý message.

Field trong request botSchedule:

Field	Bắt buộc	Ghi chú
timezone	Không	Nếu không truyền thì mặc định Asia/Ho_Chí_Minh
workingDays	Có	Danh sách ngày theo enum .NET DayOfWeek, ví dụ Monday, Tuesday
startTime	Có	Format HH:mm
endTime	Có	Format HH:mm

Ví dụ:

```
{
  "timezone": "Asia/Ho_Chi_Minh",
  "workingDays": [
    "Monday",
    "Tuesday",
    "Wednesday",
    "Thursday",
    "Friday"
  ],
  "startTime": "08:00",
  "endTime": "17:30"
}
```

Rule:

- Schedule được check theo timezone cấu hình của schedule.
- Nếu timezone không hợp lệ, request bị reject.
- Hỗ trợ schedule qua ngày, ví dụ 18:00 đến 00:00, hoặc 22:00 đến 06:00.
- Không cho phép startTime bằng endTime.
- Không cho phép overlap schedule sau khi expand qua ngày.

5.7 Cập Nhật Social Media Page

- Endpoint: PUT
/api/business-partners/{businessPartnerId}/social-media/pages/{pageId}
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE
- API này chỉ được dùng để cập nhật status của page và Bot Schedule của page.
- Nếu page đã bị soft delete hoặc integration cha đã bị soft delete thì trả NotFound theo convention hiện tại.

Request:

```
{
  "status": "Inactive",
  "botSchedule": {
    "timezone": "Asia/Ho_Chi_Minh",
    "workingDays": [
      "Monday",
      "Tuesday",
      "Wednesday",
      "Thursday",
      "Friday"
    ],
  },
}
```

```
"startTime": "08:00",
"endTime": "17:30"
}
}
```

Response 200:

```
{
  "pagelId": "19191919-1919-1919-1919-191919191919",
  "status": "Inactive",
  "schedules": [
    {
      "id": "20202020-2020-2020-2020-202020202020",
      "dayOfWeek": "Monday",
      "startTime": "08:00",
      "endTime": "17:30",
      "timeZoneId": "Asia/Ho_Chi_Minh",
      "isActive": true
    }
  ]
}
```

Không dùng API này để đổi:

- externalPagelId
- businessPartnerId
- integrationId
- Provider
- applId
- appSecret

5.8 Xóa Social Media Integration

- Endpoint: DELETE
/api/business-partners/{businessPartnerId}/social-media/integrations/{integrationId}
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE
- Response: 204 No Content.
- Đây là soft delete, không hard delete database record.

Khi xóa integration, hệ thống soft delete:

- BusinessPartnerSocialMediaIntegration

- Các BusinessPartnerSocialMediaPage thuộc integration đó
- Các BotWorkingSchedule thuộc các page đó

Các API get/listing thông thường không trả về dữ liệu đã soft delete.

5.9 Xóa Social Media Page

- Endpoint: DELETE
/api/business-partners/{businessPartnerId}/social-media/pages/{pageId}
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE
- Response: 204 No Content.
- Đây là soft delete, không hard delete database record.

Khi xóa page, hệ thống soft delete:

- BusinessPartnerSocialMediaPage
- Các BotWorkingSchedule của page đó

Integration cha không bị soft delete khi xóa một page.

5.10 Legacy Facebook App Config Và Page APIs

Các API dưới đây vẫn tồn tại trong controller hiện tại, nhưng không phải flow tạo mới chính. FE chỉ nên dùng nếu có màn hình legacy, vận hành OAuth cũ, hoặc nghiệp vụ riêng đã thống nhất.

API	Trạng thái	Ghi chú
POST /api/business-partners/{businessPartnerId}/social-media/facebook/app-config	Legacy	Tạo app config riêng
PUT /api/business-partners/{businessPartnerId}/social-media/facebook/app-config	Legacy	Cập nhật app config riêng
POST /api/business-partners/{businessPartnerId}/social-media/facebook/oauth/start	Vẫn dùng cho OAuth cũ	Bắt đầu OAuth Facebook theo integration đã config
GET /api/social-media/facebook/oauth/callback	Vẫn dùng cho OAuth cũ	Meta redirect về backend
GET /api/business-partners/{businessPartnerId}/social-media/facebook/pages	Legacy/OAuth cũ	Lấy page từ Meta sau OAuth
POST /api/business-partners/{businessPartnerId}/social-media/facebook/pages	Legacy	Lưu/chọn pages riêng, có page access token

PUT /api/business-partners/{businessPartnerId}/social-media/pages/{pageId}/bot-status	Legacy	Flow mới dùng PUT /social-media/pages/{pageId}
GET /api/business-partners/{businessPartnerId}/social-media/pages/{pageId}/schedules	Vẫn dùng để xem schedule	Không trả schedule đã soft delete
PUT /api/business-partners/{businessPartnerId}/social-media/pages/{pageId}/schedules	Legacy	Flow mới update schedule qua PUT /social-media/pages/{pageId}

BotWorkingScheduleResponse hiện có thêm timeZoneId:

```
{
  "id": "20202020-2020-2020-2020-202020202020",
  "dayOfWeek": "Monday",
  "startTime": "08:00",
  "endTime": "17:30",
  "timeZoneId": "Asia/Ho_Chi_Minh",
  "isActive": true
}
```

6. Meta OAuth Client-Driven Integration

Đây là flow khác với mục 5. Flow này dùng endpoint /api/integrations/meta, FE lấy login URL, user authorize trên Meta, Meta redirect về FE, sau đó FE post code/state/appSecret về BE. BE đổi token, verify scopes, lấy pages và lưu page tokens dạng mã hóa. API response chỉ trả hasAccessToken, không trả raw token.

6.1 Tạo Meta Login URL

- Endpoint: GET
/api/integrations/meta/login-url?appId={appId}&redirectUrl={redirectUrl}&forceRequest=false
- Permission: SOCIAL_MEDIA.FACEBOOK_INTEGRATION.REAUTHORIZE

Response 200:

```
{
  "loginUrl": "https://www.facebook.com/v23.0/dialog/oauth?...",
  "state": "opaque-state",
  "expiresAt": "2026-06-16T10:10:00Z"
}
```

6.2 Xử Lý Meta OAuth Callback

- Endpoint: POST /api/integrations/meta/oauth/callback
- Auth: source hiện tại không gắn [Authorize].

Request:

```
{
  "appId": "123456789",
  "appSecret": "meta-app-secret",
  "redirectUrl": "https://app.example.com/meta/callback",
  "code": "code-from-meta",
  "state": "state-from-login-url",
  "error": null,
  "errorReason": null,
  "errorDescription": null
}
```

Response 200:

```
{
  "success": true,
  "message": "Meta OAuth completed successfully.",
  "pages": [
    {
      "pageId": "page-id",
      "pageName": "SAR Coffee Page",
      "avatarUrl": "https://example.com/avatar.png",
      "hasAccessToken": true
    }
  ]
}
```

Security note: appSecret và page access token là secret. Không log, không persist ở browser storage, không trả raw token về client.

7. Meta/Facebook Webhook

Webhook endpoints không dùng Bearer token vì Meta/Facebook gọi trực tiếp vào backend.

7.1 Verify Meta Webhook

- Endpoint: GET
/api/webhooks/meta/{channel}?hub.mode=subscribe&hub.verify_token={token}&hub.challenge={challenge}
- Auth: anonymous.
- Khi gọi: Facebook Developer webhook verification.

Response 200: challenge từ query.

Ví dụ:

GET

/api/webhooks/meta/facebook?hub.mode=subscribe&hub.verify_token=verify-token&hub.challenge=12345

7.2 Receive Meta Webhook

- Endpoint: POST /api/webhooks/meta/{provider}
- Auth: anonymous.
- Header bắt buộc: x-hub-signature-256.
- Body: raw Meta webhook payload.

Request mẫu:

POST /api/webhooks/meta/facebook

x-hub-signature-256: sha256=...

Content-Type: application/json

```
{
  "object": "page",
  "entry": [
    {
      "id": "123456789",
      "time": 1710000000,
      "messaging": [
        {
          "sender": {
            "id": "psid"
          },
          "recipient": {
            "id": "123456789"
          },
          "timestamp": 1710000000,
          "message": {
            "mid": "message-id",
            "text": "Hello"
          }
        }
      ]
    }
  ]
}
```

Response thành công: 200 OK body rỗng.

Lỗi security:

- 400 plain text: Missing Meta webhook signature.

- 401 plain text: Invalid Meta webhook signature.
- 400 plain text: Webhook payload is required.

7.3 Rule Xử Lý Message Từ Meta/Facebook

Hệ thống chỉ lưu và publish message vào queue xử lý bot khi message thuộc Social Media Page đã đăng ký với Business Partner và page đó hợp lệ.

Flow:

Meta Webhook Received

|

v

Validate webhook request/signature

|

v

Extract Provider, PageId, SenderId, Message

|

v

Check Page registered with Business Partner

|

v

Check Page/Integration/BusinessPartner status

|

v

Check Bot Schedule by schedule timezone

|

v

Valid => Save event/message => Publish to RabbitMQ/Process Bot

Invalid => Do not save, do not publish queue, do not call chatbot API, log reject reason

Các rule reject:

- Message từ page chưa đăng ký không được xử lý.
- Message từ page inactive, bot disabled hoặc đã soft delete không được xử lý.
- Message từ integration bị soft delete, inactive hoặc chưa active không được xử lý.
- Message từ Business Partner inactive hoặc đã soft delete không được xử lý.
- Message ngoài Bot Schedule của page không được xử lý.
- Message không hợp lệ không được publish vào RabbitMQ queue xử lý bot.
- Message không hợp lệ không được gọi chatbot API.
- Webhook vẫn trả success cho Meta trong các case reject hợp lệ để tránh Meta retry liên tục. Trường hợp sai signature/security vẫn trả lỗi security tương ứng.

Reject reason hiện dùng cho internal logging:

Reason	Ý nghĩa
PageNotRegistered	Không tìm thấy page theo provider + recipient.id
PageInactive	Page bị inactive, bot disabled hoặc soft delete
BusinessPartnerInactive	Business Partner không hợp lệ hoặc inactive
IntegrationNotFound	Không tìm thấy integration/provider hợp lệ
IntegrationDeleted	Integration đã soft delete
IntegrationInactive	Integration chưa ở trạng thái Active
OutsideBotWorkingSchedule	Thời điểm message đến nằm ngoài Bot Schedule

Backend note: duplicate webhook event theo EventId sẽ bị skip. Conversation automation được scope theo PageId + SenderId/PSID.

8. Security Notes

Không log các thông tin nhạy cảm:

- appSecret
- accessToken
- pageAccessToken
- Secret/token đã decrypt
- Refresh token

Quy tắc lưu và response:

- ProtectedAppSecret lưu secret ở dạng protected/encrypted.
- Page access token nếu có phải được lưu an toàn.
- API response không trả raw secret/token.
- Khi deploy container hoặc nhiều instance, Data Protection key ring cần storage persistent/shared để token đã mã hóa vẫn decrypt được sau restart/redeploy.
- Endpoint webhook POST cần raw body nguyên vẹn để validate signature.
Proxy/gateway không nên mutate body.

9. Tổng Hợp Endpoint Nhanh

M et ho d	Endpoint	A u t h	Permission	Ghi chú
--------------------	----------	------------------	------------	---------

P O S T	/api/auth/login	N o	-	Login
P O S T	/api/auth/refresh-token	N o	-	Refresh token
P O S T	/api/auth/logout	N o	-	Logout
G E T	/api/me	Y e s	-	Profile
G E T	/api/me/permissions	Y e s	-	Permission/menu
G E T	/api/business-partners	Y e s	BUSINESS_PARTNER.PR OFILE.VIEW	Không trả soft-deleted
G E T	/api/business-partners/{id}	Y e s	BUSINESS_PARTNER.PR OFILE.VIEW	Detail
P O S T	/api/business-partners	Y e s	BUSINESS_PARTNER.PR OFILE.CREATE	Create
P U T	/api/business-partners/{id}	Y e s	BUSINESS_PARTNER.PR OFILE.UPDATE	Update
D E L E T E	/api/business-partners/{id}	Y e s	BUSINESS_PARTNER.PR OFILE.DELETE	Deactivate/delete theo service hiện tại
G E T	/api/social-media/providers	Y e s	SOCIAL_MEDIA.FACEBO OK_INTEGRATION.VIEW	Providers
G E T	/api/business-partners/{id}/s ocial-media/integrations	Y e s	SOCIAL_MEDIA.FACEBO OK_INTEGRATION.VIEW	Không trả soft-deleted
G E T	/api/business-partners/{id}/s ocial-media/integrations/{inte grationId}	Y e s	SOCIAL_MEDIA.FACEBO OK_INTEGRATION.VIEW	Không trả soft-deleted
P O S T	/api/business-partners/{id}/s ocial-media/integrations	Y e s	SOCIAL_MEDIA.FACEBO OK_INTEGRATION.CREA TE	Flow chính tạo integration + pages + schedules
P U T	/api/business-partners/{id}/s ocial-media/pages/{pageId}	Y e s	SOCIAL_MEDIA.FACEBO OK_INTEGRATION.UPDA TE	Chỉ update status + Bot Schedule

DELETE	/api/business-partners/{id}/social-media/integrations/{integrationId}	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE	Soft delete integration + pages + schedules
DELETE	/api/business-partners/{id}/social-media/pages/{pageId}	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE	Soft delete page + schedules
POST	/api/business-partners/{id}/social-media/facebook/app-config	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.CREATE	Legacy
PUT	/api/business-partners/{id}/social-media/facebook/app-config	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE	Legacy
POST	/api/business-partners/{id}/social-media/facebook/oauth/start	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.REAUTHORIZE	OAuth cũ
GET	/api/social-media/facebook/oauth/callback	No	-	OAuth callback cũ
GET	/api/business-partners/{id}/social-media/facebook/pages	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.VIEW	Legacy/OAuth cũ
POST	/api/business-partners/{id}/social-media/facebook/pages	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE	Legacy
PUT	/api/business-partners/{id}/social-media/pages/{pageId}/bot-status	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.UPDATE	Legacy
GET	/api/business-partners/{id}/social-media/pages/{pageId}/schedules	Yes	SOCIAL_MEDIA.BOT_SCHEDULE.VIEW	Xem schedule
PUT	/api/business-partners/{id}/social-media/pages/{pageId}/schedules	Yes	SOCIAL_MEDIA.BOT_SCHEDULE.UPDATE	Legacy replace schedule
GET	/api/integrations/meta/login-url	Yes	SOCIAL_MEDIA.FACEBOOK_INTEGRATION.REAUTHORIZE	Meta OAuth client-driven
POST	/api/integrations/meta/oauth/callback	No	-	Meta OAuth client-driven callback
GET	/api/webhooks/meta/{channel}	No	-	Meta verify
POST	/api/webhooks/meta/{provider}	No	-	Meta receive message

Các endpoint permission/role/menu configuration vẫn giữ như mục 4 và theo source hiện tại.

10. Kiểm Tra Tài Liệu

- Thuật ngữ dùng thống nhất: Business Partner, Social Media Integration, Social Media Page, Bot Schedule, Meta/Facebook.
- JSON sample trong tài liệu là JSON hợp lệ.
- Không có secret/token thật trong tài liệu.
- Flow tạo mới Social Media Integration dùng một API duy nhất để tạo integration + pages + schedules.
- Webhook chỉ xử lý message từ page đã đăng ký, đang hợp lệ và nằm trong Bot Schedule.